Informe de incidente de seguridad

Sección 1: Identificar el protocolo de red implicado en el incidente
Protocolos de red identificados durante la investigación: DNS, HTTP y TCP (sobre IP), correspondientes a las capas del Modelo TCP/IP. • DNS (capa de aplicación): el navegador solicita al servidor DNS (dns.google) la dirección IP de yummyrecipesforme.com y recibe 203.0.113.22. Más adelante se repite una consulta DNS para greatrecipesforme.com, que resuelve a 192.0.2.172. • HTTP (capa de aplicación): el navegador solicita la página con el método HTTP: GET / HTTP/1.1 sobre el puerto 80 (sufijo .http). • TCP (capa de transporte): el protocolo de enlace de tres vías es visible en los indicadores (Flags) [S] inicio de conexión, [S.] y [.] confirmación (ACK). • IP (capa de Internet): direccionamiento entre el equipo de origen y los destinos. El protocolo principal implicado en el redireccionamiento malicioso es HTTP, apoyado por DNS para la resolución de nombres, todo transportado sobre TCP/IP.

Sección 2: Documentar el incidente
Resumen del incidente: El sitio web yummyrecipesforme.com, que vende recetas y libros de cocina, fue comprometido. Qué ocurrió: Un antiguo empleado ejecutó un ataque de fuerza bruta contra la cuenta administrativa del host web, probando repetidamente contraseñas por defecto conocidas hasta acertar. La cuenta de administrador mantenía la contraseña por defecto y no existían controles para limitar los intentos de inicio de sesión. Tras obtener acceso al panel de administración, el atacante modificó el código fuente e insertó una función JavaScript que solicitaba a los visitantes descargar y ejecutar un archivo. Luego cambió la contraseña de la cuenta administrativa. Los clientes que ejecutaban el archivo eran redirigidos a un sitio falso, greatrecipesforme.com, que contenía malware, y sus equipos funcionaban con mayor lentitud. Cómo se descubrió: Varias horas después, varios clientes enviaron correos al servicio de asistencia informando que el sitio les pedía descargar un archivo y que, tras ejecutarlo, la dirección cambiaba y sus equipos se ralentizaban. El propietario no pudo acceder al panel de administración y contactó al proveedor de alojamiento. Investigación: El equipo de analistas creó un entorno sandbox y ejecutó el analizador

de protocolos tcpdump accediendo a yummyrecipesforme.com. El sitio solicitó descargar un ejecutable presentado como actualización del navegador; al aceptarlo y ejecutarlo, el navegador fue redirigido a greatrecipesforme.com. El registro tcpdump mostró: una consulta DNS para yummyrecipesforme.com resuelta a 203.0.113.22; una petición HTTP GET (posible descarga del archivo malicioso); posteriormente una nueva consulta DNS para greatrecipesforme.com resuelta a 192.0.2.172; y tráfico HTTP hacia el sitio suplantado. Un analista senior confirmó el compromiso y encontró el código JavaScript inyectado que redirigía a los visitantes.
Fuentes de información y pruebas: registro de tráfico tcpdump; correos de clientes al servicio de asistencia; revisión del código fuente del sitio; confirmación del analista senior; informe del equipo de ciberseguridad.

Sección 3: Recomendar una solución para los ataques de fuerza bruta

Medida recomendada: Imponer la autenticación de dos factores (2FA).

Por qué es eficaz: Un ataque de fuerza bruta se basa en adivinar la contraseña probando muchas combinaciones. Con 2FA, la contraseña por sí sola no basta para iniciar sesión: se exige un segundo factor (por ejemplo, un código temporal de una app de autenticación o un token físico) que el atacante no posee. Así, aunque la contraseña sea débil, por defecto o quede expuesta, el acceso a la cuenta administrativa queda bloqueado sin ese segundo factor. Como complemento conviene limitar el número de intentos de inicio de sesión y exigir contraseñas seguras, pero la 2FA es la que neutraliza directamente el éxito de un ataque de fuerza bruta.
Medida complementaria clave para este caso: impedir el uso de contraseñas anteriores o por defecto. Como la causa raíz fue que la cuenta administrativa conservaba la contraseña por defecto, bloquear la reutilización de contraseñas antiguas o por defecto al restablecerlas ataca directamente esa vulnerabilidad.
Conviene además exigir contraseñas largas (15 caracteres o más), que ofrecen mayor protección frente a la fuerza bruta.